

PeachtreePay

ISO/IEC 27001:2022

GRC Readiness Portfolio Project

Simulated Fintech Organization | Atlanta, Georgia

Prepared as an educational cybersecurity Governance, Risk, and Compliance portfolio project.

SIMULATED GRC PORTFOLIO PROJECT - NOT A REAL CLIENT ENGAGEMENT

PeachtreePay is fictional. This project demonstrates risk assessment, control selection, evidence thinking, remediation planning, and ISO/IEC 27001 readiness concepts.

1. Executive Summary

PeachtreePay is a fictional 100-person fintech company that provides payment-processing technology to small businesses. This simulated readiness assessment evaluates information-security risks, control gaps, and remediation priorities using ISO/IEC 27001:2022 concepts.

- 15 information-security risks assessed
- Identity and access management identified as the highest-priority area
- A risk treatment plan and 90-day remediation roadmap developed
- Selected Annex A reference controls mapped in a portfolio Statement of Applicability sample
- Policies and an evidence register created to demonstrate how controls would be governed and verified

Portfolio result: The assessment concludes that PeachtreePay has a moderate-to-high simulated risk posture, with priority improvements needed in MFA, offboarding, vulnerability management, cloud security, access reviews, monitoring, incident response, and third-party risk.

2. Company Profile and ISMS Scope

PeachtreePay employs approximately 100 people and operates a cloud-based payment platform. The environment uses Microsoft 365 for identity and collaboration and AWS for application hosting. Employees use company-managed laptops and rely on several third-party SaaS and payment providers.

ISMS scope

The simulated ISMS scope covers PeachtreePay employees, business processes, Microsoft 365, AWS infrastructure, customer information, employee endpoints, internal applications, backup processes, and critical third-party services supporting the payment platform.

Interview explanation: The scope tells the organization what part of the business the ISMS covers. I defined the systems, people, data, and services that were important to the fictional company before assessing risk.

3. Asset Inventory

Asset	Type	Why It Matters
Customer database	Data	Contains customer and transaction-related information
AWS environment	Technology	Hosts the payment-processing application and supporting services
Microsoft 365	SaaS	Provides email, identity, collaboration, and business documents
Employee laptops	Endpoint	Used to access company systems and data
Source code repository	Intellectual property	Contains application source code and configuration
HR records	Data	Contains employee personal and employment information
Backup systems	Technology	Support recovery after disruption or data loss

Third-party payment services	Vendor	Support payment and business operations
------------------------------	--------	---

Risk analysis starts with understanding what the organization needs to protect. Assets can include data, systems, devices, intellectual property, people, and services.

4. Risk Assessment Methodology

PeachtreePay uses a simple 5 x 5 qualitative risk model for this portfolio exercise. Likelihood and impact are each scored from 1 to 5. The inherent risk score is calculated before proposed treatment controls. Residual risk is the estimated risk remaining after treatment.

Score	Likelihood	Impact
1	Rare	Minimal
2	Unlikely	Minor
3	Possible	Moderate
4	Likely	Major
5	Very likely	Severe

Risk score = Likelihood x Impact. Portfolio rating bands: 20-25 Critical, 12-19 High, 6-11 Medium, 1-5 Low.

Key concept: Inherent risk is the level of risk before additional treatment. Residual risk is what remains after controls or other treatment actions are considered.

5. Risk Register

ID	Risk	L	I	Score	Rating	Treatment	Residual
1	Employee account compromised because MFA is not enabled everywhere	4	5	20	Critical	Mitigate	10
2	Phishing attack steals employee credentials	4	4	16	High	Mitigate	8
3	Former employee retains access after termination	3	5	15	High	Mitigate	5
4	AWS misconfiguration exposes customer information	3	5	15	High	Mitigate	5
5	Critical third-party vendor suffers a security breach	3	4	12	High	Mitigate/Transfer	8
6	Employee laptop is lost or stolen	3	4	12	High	Mitigate	6
7	Malware or ransomware disrupts business operations	3	5	15	High	Mitigate	8
8	Sensitive information is accidentally emailed to the wrong person	3	4	12	High	Mitigate	6
9	Excessive user permissions allow unauthorized access	3	5	15	High	Mitigate	5
10	Backups fail during a major incident	2	5	10	Medium	Mitigate	5
11	Vulnerable software remains unpatched	4	4	16	High	Mitigate	8
12	Employees are not adequately trained on security	4	3	12	High	Mitigate	6
13	Security logs are not reviewed and attacks go undetected	3	4	12	High	Mitigate	6
14	Weak vendor security assessment allows risky suppliers	3	4	12	High	Mitigate	6
15	Incident response procedures are incomplete or untested	3	5	15	High	Mitigate	5

Example reasoning: the MFA risk is Likelihood 4 because credential attacks are common, and Impact 5 because a compromised account could expose sensitive information or enable further access. After MFA and monitoring, likelihood is reduced, lowering residual risk.

6. Risk Treatment Plan

The treatment plan converts identified risks into business actions. Each risk receives a treatment decision, owner, priority, target timeline, and expected residual risk.

Risk	Treatment	Owner	Target	Primary Action
MFA/account compromise	Mitigate	IT/Security	30 days	Require MFA on critical systems
Former employee access	Mitigate	HR + IT	30 days	Formal offboarding workflow
Unpatched vulnerabilities	Mitigate	IT/Security	30 days	Define vulnerability remediation SLAs
AWS misconfiguration	Mitigate	Cloud/Security	60 days	Cloud baseline and configuration review
Excessive access	Mitigate	IT/GRC	60 days	Quarterly access reviews
Untested incident response	Mitigate	Security/GRC	60 days	Conduct tabletop exercise
Vendor risk	Mitigate/Transfer	GRC/Legal	90 days	Vendor security reviews and contractual controls
Interview explanation: GRC may not be the team that technically implements every fix. The GRC role can identify and score the risk, recommend treatment, assign or coordinate ownership, track remediation, and collect evidence.				

7. ISO 27001 Readiness Gap Assessment

Security Area	Current State	Gap	Recommendation
MFA	Admins only	Regular users are not consistently protected	Require MFA company-wide
Access reviews	Informal	Permissions are not periodically reviewed	Quarterly access reviews
Offboarding	Manual email process	Accounts can be missed	Formal HR/IT workflow
Security awareness	New-hire only	No recurring training	Annual training plus phishing exercises
Vulnerability management	Ad hoc	No standard remediation timelines	Formal scanning and remediation SLAs
Cloud security	Engineer-managed	No formal configuration review	Cloud security baseline and reviews
Incident response	Basic plan exists	No consistent testing	Annual tabletop exercise
Backups	Automated	Restore tests inconsistent	Quarterly restoration tests
Logging	Logs remain in separate systems	No centralized monitoring	Centralize high-value logs/SIEM
Vendor security	Procurement review only	Security is not formally evaluated	Vendor risk management process
Endpoint security	AV deployed	Endpoint monitoring is inconsistent	EDR and standard configurations
Encryption	Mostly implemented	Standards are not formally documented	Document encryption requirements

12 gap areas reviewed. This table matches the workbook. A risk assessment asks what could happen to the business; a gap assessment identifies missing or insufficient practices.

8. Statement of Applicability - Portfolio Sample

For ISO/IEC 27001:2022, the organization determines necessary controls through risk treatment and compares them with Annex A so necessary controls are not omitted. The Statement of Applicability

documents necessary controls and related justifications. This portfolio includes a selected-control sample rather than reproducing the entire standard.

Control	Area	Applicable	Status	Portfolio Justification
A.5.15	Access control	Yes	Partial	Employees require controlled access to sensitive systems
A.5.16	Identity management	Yes	Partial	User identities need lifecycle management
A.5.18	Access rights	Yes	Partial	Permissions need least-privilege reviews
A.5.19	Supplier relationships	Yes	Partial	The company relies on cloud and SaaS vendors
A.5.23	Cloud services	Yes	Partial	AWS supports critical company services
A.5.24	Incident management planning	Yes	Partial	Security incidents require structured response
A.6.3	Security awareness	Yes	Partial	Employees can introduce security risk
A.6.5	Post-employment responsibilities	Yes	Partial	Access must be removed when employment ends
A.8.1	User endpoint devices	Yes	Partial	Employees use laptops to access company systems
A.8.7	Protection against malware	Yes	Implemented	Endpoints require malware protection
A.8.8	Technical vulnerabilities	Yes	Partial	Systems require vulnerability management
A.8.13	Information backup	Yes	Partial	Business data must be recoverable
A.8.15	Logging	Yes	Partial	Security events need records
A.8.16	Monitoring activities	Yes	Partial	Suspicious activity needs detection
Important: The SoA is not just a box-checking list. The key reasoning is: identify risks, determine controls, compare them to Annex A, justify applicability, and track implementation.				

9. Information Security Policy

Purpose: establish PeachtreePay's overall expectations for protecting company, customer, and employee information.

- Protect confidentiality, integrity, and availability of information.
- Apply security responsibilities across management, IT, Security/GRC, and employees.
- Use risk management to identify, assess, treat, and monitor information-security risk.
- Apply least privilege, MFA for critical systems, periodic access reviews, and prompt access removal.
- Provide security awareness training and maintain vulnerability, incident, vendor, backup, and continuity practices.
- Review the policy at least annually or after significant organizational or technology change.

10. Access Control Policy

- Access must be based on business need and least privilege.
- New accounts require appropriate approval before provisioning.

- MFA is required for Microsoft 365, AWS, administrative access, remote access, and sensitive applications.
- Critical-system access is reviewed quarterly.
- Role changes trigger an access review and removal of no-longer-needed permissions.
- Termination triggers prompt account disablement, session revocation, privileged-access removal, and equipment recovery.
- Third-party access must have a documented purpose, approval, limited scope, and end date or removal process.

Policy vs. procedure: A policy states what the organization requires. A procedure explains the exact steps used to meet that requirement. Example: the policy requires termination access removal; the procedure defines the HR ticket, account-disablement steps, evidence, and closure process.

11. Incident Response Policy

PeachtreePay uses a consistent incident-response lifecycle:

1. Identification - determine whether suspicious activity is a security incident.
2. Investigation - determine what happened, when, which systems were affected, and what information may be involved.
3. Containment - stop additional harm, such as disabling a compromised account or isolating a device.
4. Eradication - remove the cause, such as malware, vulnerable configuration, or compromised credentials.
5. Recovery - restore systems safely and monitor for recurrence.
6. Lessons learned - document root cause, control failures, response effectiveness, and remediation.

Significant incidents should be documented, evidence should be preserved where appropriate, and the response process should be periodically tested through tabletop exercises.

12. Evidence Register

Control Area	Example Evidence	What It Demonstrates
MFA	Microsoft 365/AWS MFA configuration report	MFA is enabled for required users
User provisioning	Approved access request tickets	Access was approved before being granted
Access reviews	Quarterly access review records	Permissions are periodically reviewed
Offboarding	Termination ticket and disabled account record	Former employee access was removed
Security awareness	Training completion report	Required training was completed
Endpoint security	EDR dashboard/report	Endpoints are monitored and protected
Vulnerability management	Vulnerability scan report	Weaknesses are being identified
Patch management	Patch compliance report	Systems receive security updates
Cloud security	Cloud configuration review	Cloud controls were reviewed
Logging and monitoring	SIEM alerts/investigation tickets	Suspicious activity is reviewed
Backups	Backup logs and restore-test record	Data is backed up and recoverable
Vendor security	Completed vendor questionnaire	Supplier security was evaluated
Incident response	Tabletop exercise report	Response procedures were tested
Audit thinking: A policy can show that a requirement exists, but operational evidence shows whether the control is actually being performed. For example, an access-control policy says quarterly reviews occur; completed quarterly review records demonstrate execution.		

13. 90-Day Remediation Roadmap

First 30 Days

- Require company-wide MFA on critical systems.
- Formalize the HR-to-IT offboarding workflow.
- Define vulnerability remediation timelines and escalation.

Days 31-60

- Perform an AWS security configuration review.
- Implement quarterly access reviews.
- Centralize important security logging and alerting.
- Conduct an incident-response tabletop exercise.

Days 61-90

- Formalize vendor risk tiering and security questionnaires.
- Strengthen recurring security awareness and phishing exercises.
- Perform and document a backup restoration test.

Ongoing

- Quarterly access reviews
- Vulnerability scanning and patch monitoring
- Vendor reassessment
- Security awareness
- Backup testing
- Risk-register updates
- Annual policy review
- Incident-response exercises

14. Interview Walkthrough

A natural 30-second explanation:

I built a simulated ISO 27001 readiness assessment for a fictional fintech company. I defined the ISMS scope and key assets, created a risk methodology and risk register, scored inherent risk, recommended treatments, estimated residual risk, performed a gap assessment, and mapped selected controls in a Statement of Applicability. I also created sample policies, an evidence register, and a 90-day remediation roadmap.

Follow-up questions to be ready for

Why was MFA your first priority?

It addressed one of the highest-rated risks and reduced several related risks, including phishing and account takeover, while being practical to implement.

What is residual risk?

The risk remaining after controls or treatment actions are considered.

What is a risk owner?

The person or business function accountable for making sure a risk is appropriately managed, even if another team implements the technical fix.

What is the difference between a policy and evidence?

A policy documents what is required. Evidence demonstrates that the control or process is actually being performed.

What is the difference between a risk assessment and a gap assessment?

Risk assessment asks what could happen and how serious it would be. Gap assessment asks what expected control or practice is missing or insufficient.

15. Project Lessons Learned

- ISO 27001 is a management system and risk-management approach, not just a list of technical controls.
- Business context and scope come before control selection.
- Risk scores need documented reasoning, not just numbers.
- Controls should reduce risk to an acceptable level rather than attempting to eliminate every risk.
- Evidence is essential for demonstrating that controls operate in practice.
- Remediation must be prioritized based on risk, business impact, effort, and dependencies.

References

ISO. ISO/IEC 27001:2022 - Information security management systems - Requirements.
<https://www.iso.org/standard/27001>

ISO/IEC JTC 1/SC 27 Auditing Practices Group. Statement of Applicability and conformity discussion.
https://committee.iso.org/files/live/sites/jtc1sc27/files/resources/ISO-IECJTC1-SC27-WG1_N3298_Auditing%20Practices%20Note%20-%20SoA.pdf

ISO/IEC JTC 1/SC 27 Journal 2025. Discussion of Annex A controls and the relationship to ISO/IEC 27001.
<https://committee.iso.org/files/live/sites/jtc1sc27/files/resources/Journal%202025.pdf>